11.4.6 Certificate-bound access tokens

Beyond supporting client authentication, the OAuth2 mTLS specification also describes how the AS can optionally *bind* an access token the TLS client certificate when it is issued, creating a *certificate-bound access token*. The access token then can be used to access an API only when the client authenticates to the API using the same client certificate and private key. This makes the access token no longer a simple bearer token, because an attacker that steals the token can't use it without the associated private key (which never leaves the client).

> **DEFINITION** A ***certificate-bound access token*** can't be used except over a TLS connection that has been authenticated with the same client certificate used when the access token was issued.

Proof-of-possession tokens

Certificate-bound access tokens are an example of *proof-of-possession* (PoP) tokens, also known as *holder-of-key* tokens, in which the token can't be used unless the client proves possession of an associated secret key. OAuth 1 supported PoP tokens using HMAC request signing, but the complexity of implementing this correctly was a factor in the feature being dropped in the initial version of OAuth2. Several attempts have been made to revive the idea, but so far certificate-bound tokens are the only proposal to have become a standard.

Although certificate-bound access tokens are great when you have a working PKI, they can be difficult to deploy in some cases. They work poorly in single-page apps and other web applications. Alternative PoP schemes are being discussed, such as a JWT-based scheme known as DPoP (https://tools.ietf.org/html/draft-fett-oauth-dpop-03), but these are yet to achieve widespread adoption.